

1. 업무개요

□□□□본부(△△△△처 ○○○○부, 이하 “○○○○부”라 한다)는 「정보보안 업무지침」 제52조에 따른 라 시스템의 관리부서로서, 서비스 개시일인 20xx. xx. xx.부터 라 시스템을 운영하고 있다.

2. 관련규정 및 판단기준

「개인정보 보호법」 제29조에 따르면 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 안정성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

이에 「개인정보의 안정성 확보조치 기준」(개인정보보호위원회 고시) 제5조에서는 개인정보처리자는 전보 또는 퇴직 등 인사이동이 발생하여 개인정보취급자가 변경되었을 경우 지체없이 개인정보처리시스템의 접근권한을 변경 또는 말소하도록 정하고 있다.

또한, 같은 지침 제6조 제2항에서는 개인정보처리자는 개인정보취급자가 인터넷 등 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 가상사설망 또는 전용선 등 안전한 접속수단을 적용하거나 안전한 인증수단을 적용하도록 정하고 있다.

이에 공단 「정보보안 업무지침」 제76조에서는 공용 정보시스템 관리자가 개별사용자의 보직변경, 퇴직, 계약종료 등 인사 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하도록 정하고 있으며, 제77

조 제3항에서는 공용 정보시스템에서 개별사용자를 식별 또는 인증하기 위하여 비밀번호에 갈음하거나 병행하여 지문인식 등 생체인증 기술 및 일회용 비밀번호 생성기(OTP¹⁰⁾) 등을 안전성 확인 후 사용할 수 있도록 정하고 있다.

따라서 ○○○○는 공용 정보시스템인 [라] 시스템에 대한 비인가 접근을 통제하고 업무 목적에 따른 접근권한을 최소한으로 부여할 수 있도록 사용자 등록·해지 및 접근권한의 부여·변경·말소 절차를 수립·이행하고, 인터넷 등 정보통신망을 통하여 외부에서 [라] 시스템에 접속하려는 경우에는 법적 요구사항에 따라 안전한 접속수단 또는 안전한 인증수단을 적용하여야 했다.

3. 감사결과 확인된 문제점

이번 "디지털시스템 운영실태 점검 특정감사" 기간 중 [라] 시스템의 사용자 계정관리 실태를 확인한 결과, 다음과 같은 문제점을 확인하였다.

가. 사용자 접근권한 말소 및 계정 삭제 등에 관한 관리기준 부재

공단 임직원은 통합포털시스템 내 계정 신청 기능을 통해 1인당 1계정에 한하여 [라] 개인계정을 생성할 수 있으며, 부서(사업) 단위 공용 사용 목적의 통합 [라] 계정(이하 "부서용 계정"이라 한다)이 필요한 경우 활용 용도 및 사용기간 등을 명시한 부서용 계정 생성 신청공문 제출 후 ○○○○부의 승인을 통해 생성할 수 있다.

점검일(2023. x. x.) 기준 [라] 시스템의 개인 및 부서용 등 사용자 계정 현황은 [표 2]와 같다.

10) 일회용 비밀번호(One Time Password), 기존 계정정보(ID, 비밀번호) 로그인의 보안 취약점 개선을 위한 추가 인증 수단

[표 2] ㉠ 시스템 사용자 계정 현황

계정 상태	개인계정	부서용 계정	기타(테스트 계정 등)
정상	x,xxx	xxx	x
휴면	xxx	xx	x
사용 중지	xx	x	x
소계	x,xxx	xxx	x
총계	x,xxx		

○○○○부는 ㉠ 시스템 사용자 계정을 경영정보시스템(MIS) 내 인사정보와 동기화하여 계정을 사용 중인 임직원의 휴직 명령 등 장기간 미사용 시 ‘휴면 계정’ 상태로, 퇴직 또는 면직 등 접근권한 말소 사유 발생 시 ‘사용 중지’ 상태로 자동전환시키는 방식으로 개인계정 접근권한의 변경·말소를 관리하고 있다.

그런데 ‘사용 중지’ 상태의 개인계정에 대한 기존 사용자의 인사 변동사항을 점검한 결과, 감사일(20xx. x. x.) 기준 최대 x,xxx일(약 x년 x개월) 전 공단을 퇴직한 사용자를 포함한 기존 사용자 xx명 전원이 퇴직 또는 면직하여 해당 개인계정의 접근권한은 자동 말소 처리되었으나 계정 및 데이터의 삭제 조치가 이루어지지 않고 시스템 내 저장되어 있는 것으로 확인되었다.

또한, 부서용 계정의 경우 사용기간 제한, 접근권한 자동 말소 등의 관리 기준이 없어, 부서용 계정 사용자를 대상으로 별도 현황 조사를 실시하여 계정의 지속 사용 또는 해지 여부를 결정하고 있는 실정이다.

따라서, ○○○○부는 사용자의 퇴직 및 면직에 따라 접근권한이 말소된 개인계정의 해지 및 데이터 영구삭제, 부서용 계정의 신청 및 해지 등에 대한 관리 기준을 마련할 필요가 있다.

나. 통합메일계정에 대한 보안관리 미흡

한편, ○○○○부는 [라] 시스템의 기존 계정 정보(ID/Password) 로그인 방식에 대한 보안 취약점 개선을 위해 20xx년 x월 [라] 시스템에 OTP 추가 인증 방식의 이중 인증체계를 도입하여 운영 중이다.

[표 3] [라] 시스템 주요 기능개선 추진 경과

20xx년 x월	20xx년 x월	20xx년 x월	20xx년 x월
계정 신청절차 개선, 비밀번호 자동 재설정 기능적용 등	서버 노후화 등에 따른 시스템 교체, 모바일 최적화 등	로그인 시 OTP추가인증 방식 도입	직원검색 기능 등 모바일 [라] 시스템 기능개선

그런데 [라] 시스템 사용자 계정에 대한 OTP 추가 인증 등 이중 인증체계 적용 현황을 점검한 결과, OTP 추가 인증정책이 전수 적용된 개인계정과 달리 부서용 계정은 여전히 기존 계정 정보(ID/Password) 로그인 방식으로 운영 중인 것으로 확인되었다.

공공기관 사칭 피싱 범죄 등 도메인 도용, 퇴직자 및 면직자 등 접근권한이 없는 사용자의 업무시스템 접속 등을 예방하기 위해 상대적으로 보안관리가 취약한 부서용 계정에도 예외없이 OTP 추가 인증정책 등 이중 인증체계를 도입하여 통합[라] 계정에 대한 보안관리를 강화할 필요가 있다.

4. 관련자(부서) 의견

○○○○는 메일 솔루션 기능 오류로 인해 장기간 보관되어 있던 ‘사용 중지’ 상태 계정 xx건을 모두 삭제 처리하였으며, [라] 시스템 계정 관리기준 마련

을 위해 아래 사항을 포함한 「정보화업무 운영예규」 개정을 검토하겠다는 의견을 제시하였다.

가. 임직원 및 부서용 [라] 시스템 계정 관리 기준(생성, 휴면, 삭제 등)

나. 부서용 [라] 시스템 계정 2차 인증(OTP) 관리 기준

5. 조치할 사항

□□□□본부장(△△△△처장)은 [라] 시스템 사용자 계정에 대한 세부 관리 기준 및 안전한 인증수단 추가 적용 등의 통합[라] 계정 보안관리 강화방안을 마련하시기 바랍니다. **【권고】**